



UK NCSC 2026

Organisational Resilience

and the Post-Quantum Cryptography State of the Nation

Where NCSC is steering UK organisations in 2026, where the Cyber Security and Resilience Bill stands ahead of Lords report stage, and how far the UK has moved on the 2028 / 2031 / 2035 PQC milestones.



Andrew Gravett

Lead Security Architect

October 2026



UK NCSC 2026

Organisational Resilience

and the Post-Quantum Cryptography State of the Nation

Where NCSC is steering UK organisations, where the Cyber Security and Resilience Bill stands ahead of Lords report stage, and how far UK organisations really are from the 2028 / 2031 / 2035 PQC milestones.

Andrew Gravett, Lead Security Architect | October 2026

INTERACTIVE BRIEFING | 30 MINUTES

Post-Quantum Cryptography

THE 2026 UK UPDATE PART 2

Issues, advisories, assessment, implementation and planning

For UK security teams, organisations and individuals

Aligned to NCSC guidance, timelines for migration to post-quantum cryptography. Content current as at August 2026.



How the next 30 minutes work

1 Where we are Opening poll, keep your answer 2 min	6 Table exercise Six assets, four quadrants 6 min
2 The 2026 threat picture What actually changed, and what did not 4 min	7 Implementation Patterns, sequence, assurance 4 min
3 Advisories and standards Quick-fire quiz and reveal 6 min	8 Planning and suppliers Governance, budget, the six questions 1 min
4 The deployment reality Intent versus production 2 min	9 Individuals and SMEs What you actually do 1 min
5 Assessment Discovery, CBOM, prioritisation 2 min	10 Close Commitments, then what lands next 3 min

Highlighted blocks are the interactive ones. Full deck runs about 36 minutes. For a strict 30, treat slides 11, 14, 18 and 20 as handout only and compress the exercise to four minutes.

Poll: where is your organisation today?

A

Nothing started

No cryptographic discovery has begun

B

Discovery underway

Inventory in progress, no written plan yet

C

Plan written

Priorities agreed, first migrations scheduled

D

Migrating

Hybrid key exchange live in production

Hands up, or vote in the chat. Remember your letter.

We will come back to this at the end.

For context, DigiCert surveyed 1,001 decision makers across the UK, US and Australia in May 2026: 87 per cent said they were planning, testing or implementing PQC, but only 7 per cent had quantum-safe or hybrid cryptography on more than half their certificates. Gartner's September data suggests most rooms still sit at A or B: under half of CISOs have started, and only 8% can see their inventory.

The target is shrinking faster than the hardware is growing

2019

20M

Gidney and Ekerä estimate physical qubits to factor RSA-2048 in about eight hours

May 2025

<1M

Same hardware assumptions, better algorithm and error correction, under a week

Feb 2026

~100k

Iceberg Quantum's Pinnacle design, using qLDPC codes

Mar 2026

~10k

Caltech, Mar 2026: reconfigurable neutral atoms, with much longer runtimes



None of this came from new hardware.

Every reduction above is algorithmic: better factoring circuits, cheaper magic state distillation, more efficient error correcting codes. That matters for planning, because algorithmic progress arrives without warning and without a fabrication plant. Your migration timeline cannot be pinned to a hardware roadmap you can watch.

What the hardware actually does today

Where the machines are

1,121 physical qubits, IBM Condor

1,180 physical qubits, Atom Computing array

105 physical qubits, Google Willow, below threshold

48 logical qubits, Quantinuum Helios

96 logical qubits, Harvard, MIT and QuEra system

The honest position

No cryptographically relevant quantum computer exists.

Every aggressive 2026 source states this plainly. Breaking secp256k1 needs roughly 1,200 to 1,450 logical qubits on the most optimistic published estimate. Demonstrated logical qubit counts are in the tens.

The gap is still several orders of magnitude. The point is not that the threat is here. The point is that the preparation window is shorter than the migration takes.

Use this framing with your board: the threat timeline is uncertain, but the preparation timeline is not. NCSC has fixed the preparation timeline at 2028, 2031 and 2035. You are being measured against the second one, whatever the physicists do.

Harvest now, decrypt later: the only sum that matters



If the left side is bigger than the right, you are already exposed. Nothing you do in 2034 fixes data captured in 2026.

UK data that fails this test today

- Health and care records, retained for decades
- Legally privileged and regulatory correspondence
- CNI design documents, substation and plant layouts
- Long-lived roots of trust and code signing keys
- Payment and identity data with statutory retention
- Anything with a national security classification

Frame it as a threat model, not a headline

Information disclosure with a delayed trigger. Capture is happening now against a decrypt capability later. Your detection controls will never fire.

Spoofing on a later date. A forged signature against a quantum-vulnerable root is the second-order risk, and it is the one nobody has budgeted for.

84 per cent of surveyed organisations already believe some of their encrypted data is exposed to this. Very few have written it into a risk register.

What each NCSC milestone actually demands

2028 Assess and plan

- **Define migration goals** to establish clear organizational direction.
- Complete a **full discovery exercise** across the entire IT estate.
- Build initial migration plan naming **priorities, supplier dependencies & roots of trust**.
- **Communicate needs** and timelines clearly to external suppliers.

2031 Prioritise & upgrade

- Complete your **highest priority migrations**, securing critical assets first.
- **Ready the infrastructure** comprehensively for a post-quantum cryptographic future.
- **Refine the plan** into a clear, structured route to reach full migration.

2035 Complete

- **Complete migration** for all internal systems, services, and commercial products.
- **Remove sole dependence** on quantum-vulnerable public key cryptography.
- **Build broader cyber resilience** into core infrastructure while you are upgrading.

Scope note: NCSC aims this primarily at technical decision makers and risk owners in large organisations, CNI operators including industrial control systems, and anyone running bespoke IT. For SMEs on commodity IT it should arrive through vendor updates. Where you run custom or specialist software, you follow the same dates as everyone else. NCSC is also explicit that you should not be writing your own PQC implementations.

What actually changed in 2026

JAN

EU & G7 expectations

The Commission proposal to amend NIS2 would require member states to adopt national PQC transition policies. G7 Cyber Expert Group published a financial sector roadmap.

MAY

Nine signature candidates

NIST IR 8610 moved FAEST, MAYO, MQOM, QR-UOV, SDitH, SNOVA, SQIsign, and UOV into a third round expected to run about two years.

JUN

US moves to obligation

Executive Order 14412 and OMB memo M-26-15 require PQC key establishment on federal high-value systems by end 2030 and signatures by end 2031. Agency plans due in October.

UK

Standards & supplier list

National Quantum Standards Network launched. NCSC ACSC post-quantum pilot closed expressions of interest and published its assured supplier list.

JUL

AI-assisted cryptanalysis

A frontier model found a structural weakness in HAWK, cutting HAWK-256 key recovery from 2^{64} to 2^{38} . The team withdrew it. No deployed systems affected.

ONGOING

Other standards moving

HQC draft still pending. FIPS 206 final expected late 2026 or early 2027. IETF work on PQC in TLS is not finished. Plan for change, not a fixed target.

Quick-fire: true or false?

1 The HAWK result means lattice-based cryptography is broken and ML-KEM is now suspect. TRUE / FALSE

2 You have to migrate your PKI before you can turn on post-quantum key exchange. TRUE / FALSE

3 Mainstream browsers already negotiate post-quantum key exchange by default. TRUE / FALSE

4 NCSC expects mature organisations to build their own PQC implementations. TRUE / FALSE

Thumbs up for true, thumbs down for false. Commit before the reveal. All four come up again in the exercise.

The answers, and why they matter

1

FALSE

HAWK was a round 3 candidate, never a standard, and its security rested on the Lattice Isomorphism Problem. ML-KEM and ML-DSA rest on different assumptions and are unaffected. The lesson is about assurance velocity, not lattices.

2

FALSE

In TLS 1.3 the key exchange is negotiated independently of the certificate. Hybrid key exchange deploys without touching your PKI, and it is the single highest impact control available against harvest now, decrypt later.

3

TRUE

Chrome, Edge and Firefox default to the X25519 plus ML-KEM-768 hybrid group. By April 2026 more than half of human traffic reaching Cloudflare used it. Signal and Apple iMessage already protect message key agreement.

4

FALSE

NCSC is explicit: other than a very small number of firms who employ cryptographers, your plan should not involve you or your suppliers producing your own PQC implementations. Use validated modules and trusted libraries.

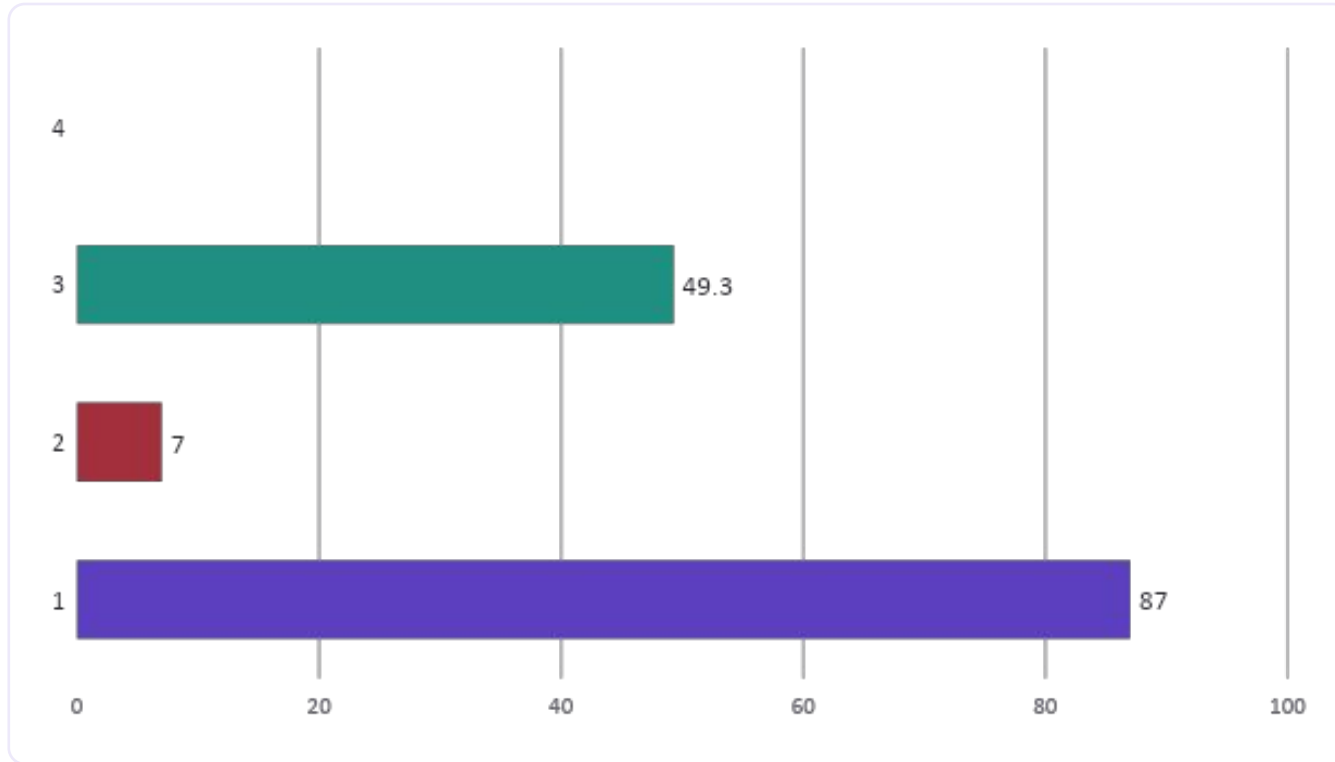
If you take one thing from this block: hybrid key exchange is available to you now, without a PKI programme, and it stops the clock on new sessions.

What is deployable, and what is not, as at October 2026

Algorithm	Standard	Status	What to do with it
ML-KEM	FIPS 203	Final, Aug 2024	Deploy now for key establishment. X25519MLKEM768 for internet-facing TLS 1.3.
ML-DSA	FIPS 204	Final, Aug 2024	Primary signature choice. Ecosystem support, not the algorithm, is your constraint.
SLH-DSA	FIPS 205	Final, Aug 2024	Conservative hash-based fallback. Large signatures. Use selectively, for example firmware.
LMS and XMSS	SP 800-208	Final, stateful	Secure boot and firmware signing only. State management is unforgiving.
FN-DSA	FIPS 206	Draft; final expected late 2026 or early 2027	Do not put it in a production baseline. Compact signatures, harder to implement safely.
HQC	Selected Mar 2025	Draft pending, final expected 2027	Roadmap item. Code-based insurance against a future break in lattice KEMs.
Additional signatures	NIST IR 8610	Round 3, nine candidates	Watch only. HAWK left this group in July 2026, which is the point of a third round.

The status boundary is a control. Final, draft, selected, candidate, validated and deployed are not synonyms. A supplier claiming compliance with an unfinished standard is telling you something about their marketing, not their engineering.

Intent has scaled. Deployment has not.



15.7%

of scanned public domains still negotiate TLS 1.2, concentrated in banking and government. Before you plan for 2035, close the gaps you already own.

The execution gap

- Deployment moved less than two percentage points in a year, from 5 to 7 per cent.
- About 75 per cent claim a live crypto inventory, yet Gartner finds only 8% of CISOs can see theirs.
- Close to half have nobody named as leading the migration.

Sources: DigiCert Quantum Readiness Outlook, July 2026, 1,001 decision makers in the UK, US and Australia. Measurement study of post-quantum readiness of the internet, 2026, 32,011 domains. Axiad readiness research, August 2026. Gartner SRM Summit London, via Computing, 22 September 2026.

Confidential sessions terminating at forgeable identities

K

Key establishment: largely solved

- X25519MLKEM768 is default in Chrome, Edge and Firefox.
- Over half of human traffic to a major CDN used it by April 2026.
- Available in OpenSSL 3.x, AWS-LC and BoringSSL today.
- ML-KEM encapsulation is faster than RSA key exchange, so performance is not your blocker.
- It requires no change to your certificate estate.

A

Authentication: barely started

- No ML-DSA roots chain into the major public trust stores.
- The CA/Browser Forum has no merged baseline requirement permitting them.
- The IETF work on ML-DSA in TLS is not finished.
- Your quantum-safe session is still authenticated by an ECDSA or RSA certificate.
- Forged signatures are a later problem that needs funding now.

NCSC names the two hardest ecosystems, and neither is your enterprise TLS

WebPKI. A decentralised ecosystem of roots, CAs, certificate transparency logs and revocation providers, with no agreed way to carry post-quantum signatures while staying compatible. Sequencing a migration across it will be hard. **ICS protocols.** Legacy protocols that were never brought up to modern cryptographic standards. Replacing them means new architectures and key management, not a library swap. Plan flexibility into your roadmap for both.

Discovery that survives contact with a real estate

1 Top down

Start from your important business services and their architectural interdependencies. Which services, which data, what lifetime, what value to an adversary, protected how in transit and at rest.

2 Bottom up

Then go looking. Scan and profile actual TLS configurations, certificate stores, key material, HSM contents and firmware images. The estate never matches the diagram, and the gap is where your risk lives.

3 Output: a CBOM

A cryptographic bill of materials, not a perfect asset register. NCSC is explicit that at this stage you need to understand the nature and scale of each system, with versions and patch levels where available, plus the dependencies between them.

Enumerate all of this, or your plan will be wrong

- Services and applications, internal and external
- Data records, with lifetime and adversary value
- Networking and comms hardware: routers, VPNs, gateways
- Servers, workstations and managed mobile devices
- IoT and ICS devices with a communications function
- Devices and tokens issued to end users, and field sensors
- Products you make or use that have a crypto function
- Anything a managed service provider runs on your behalf

Prioritise on data lifetime against migration difficulty

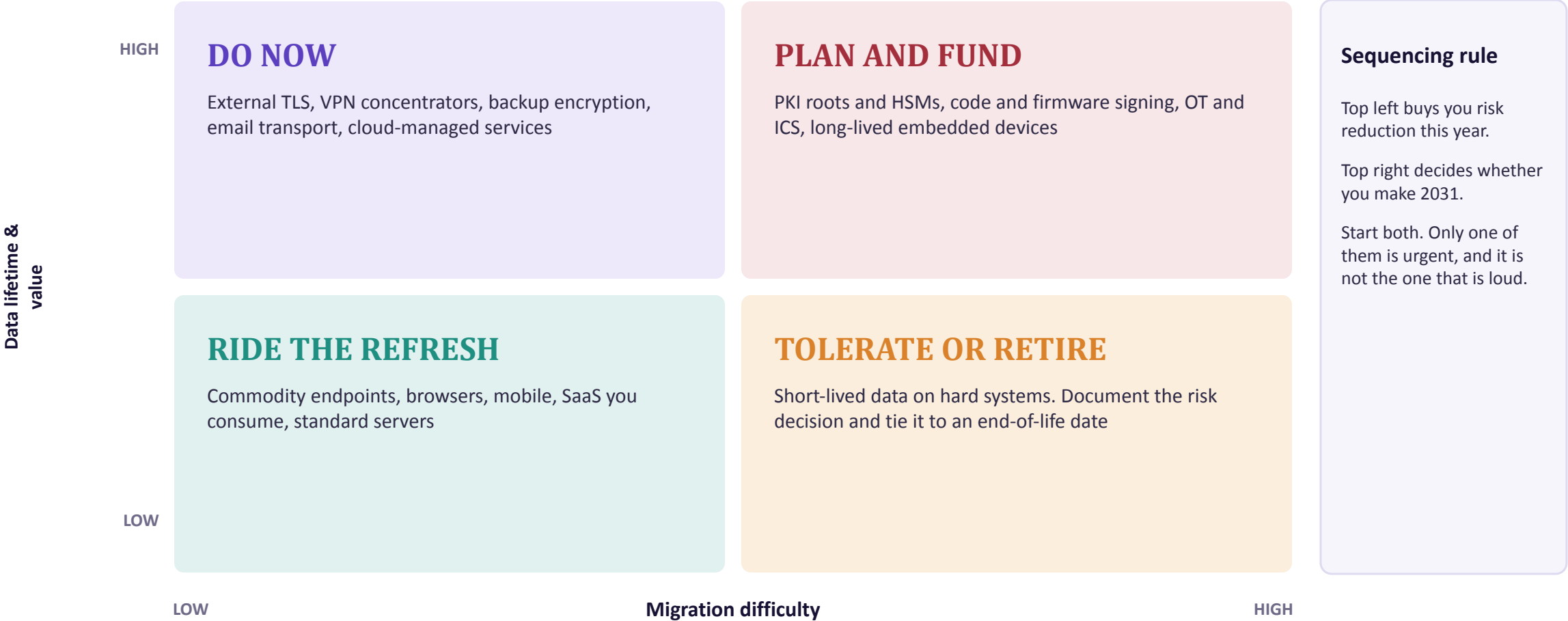


Table exercise: six assets, four quadrants

Scenario. You are the security architect for a UK regulated operator. Hybrid estate: cloud-hosted customer services, an on-premises enterprise PKI, a payments interface, and a field OT network with substation links. Board has asked what moves first and what it costs.

1 Internet-facing TLS on the customer portal
Cloud load balancer, certificates renewed every 90 days

2 Enterprise PKI root, HSM backed
15 year validity, issues to 12,000 machines and 4,000 users

3 Code signing keys for shipped firmware
40,000 field devices, signature verified at boot, no remote key rotation

4 S and MIME on legal and HR mailboxes
20 year retention obligation on the archived mail

5 Site to site VPN between two data centres
IKEv2, both ends under your control, refreshed on a 4 year cycle

6 Legacy ICS protocol on a substation link
Vendor supported to 2032, no PQC roadmap published

In your groups, five minutes: place each asset in a quadrant, name the accountable owner, and state the single first decision for the two you rank highest.

Debrief: what good looks like

1 Portal TLS	Do now	Enable the X25519 plus ML-KEM-768 hybrid group at the termination point. No certificate change, no PKI work, measurable this quarter.
2 Enterprise PKI root	Plan and fund	Longest lead time in the estate. Decide now between a parallel PQC hierarchy and cross-signing a new root. Design in 2026, build before 2031.
3 Firmware signing	Plan and fund	Stateful hash-based signatures are standardised for exactly this. The decision has to land before the next hardware tranche is committed.
4 S and MIME archive	Do now, then watch	Twenty year retention makes this genuinely urgent, but you are gated on client support. Reduce what you archive while you wait.
5 Data centre VPN	Do now	Both ends are yours, so no interoperability negotiation. Quickest real win after external TLS.
6 Legacy ICS link	Tolerate or retire	No credible path before the 2032 refresh. Write the risk acceptance down, name the owner, and tie the migration to the asset replacement.

The assets that frighten people are rarely the ones that block them. Three of these six are deployable in a sprint.

Six honest answers for any system you own

In-place migration

Swap the vulnerable public key components for PQC equivalents, minimal change elsewhere

Re-platform

Move to a platform that already supports PQC, and take the architecture review while you are there

Retire the service

Set a withdrawal date so migration never becomes necessary

Run to end of life

The system is being decommissioned inside a defined window anyway

Tolerate the risk

Operate without mitigation. Legitimate, but only when written down and owned

No action needed

Some systems use no public key cryptography at all. Prove it, then move on

The constraint you cannot design away. Except for the very simplest systems, traditional public key cryptography and PQC will co-exist in your environment for years. That means every design choice you make now should be a cryptographic agility choice: negotiable algorithms, externalised trust anchors, and a written criterion for when you switch the old suite off. You are only secure against the quantum threat once nothing has a sole dependence on traditional public key cryptography.

A defensible first eighteen months

1 Discovery

Stand up continuous cryptographic discovery. Not a one-off scan. The estate changes faster than an annual audit cycle can track.

2 TLS Exchange

Turn on hybrid key exchange everywhere you terminate TLS. X25519MLKEM768 for internet-facing services. Keep classical groups as fallback.

3 Inventory

Inventory and date every certificate, key and trust anchor. Include code signing, firmware roots, HSM contents and validity periods past 2031.

4 Supplier Roadmaps

Get supplier roadmaps in writing, with dates and algorithm names. A roadmap without a version number and a date is a marketing document.

5 PQC Test Rig

Build a PQC test rig and break something deliberately. Larger keys and signatures break assumptions in middleware, MTU handling, and HSMs.

6 PKI Design

Start the PKI design now, deliver it last. It is the slowest thing in the estate to move, and almost everything else eventually depends on it.

Steps one to three are fundable from a normal security budget and will carry you to the 2028 NCSC checkpoint.

Verify it, and design for the strictest regime you touch

V Verify, do not assume

Misconfigured cryptography does not cause an outage. It quietly weakens you, and NCSC calls this out specifically.

- Confirm the group actually negotiated per connection, not the one you configured.
- Alert on silent fallback to classical key exchange.
- Test interoperability, not just integration. Your dependencies are the failure surface.
- Track three metrics: % of clients on PQC, the named list that is not, and the date you can switch classical off.
- Ask suppliers for CAVP algorithm validation and FIPS 140-3 module validation, not a datasheet claim.

J Hybrid or pure? It depends who you serve

Germany, BSI

TR-02102-1 requires hybrid: ML-KEM combined with a classical exchange

Australia, ASD

ML-KEM-1024 without hybrid, and classical asymmetric gone by 2030

US, CNSA 2.0

Hybrid permitted in transition, exclusive PQC for networking equipment by 2030

UK, NCSC

Agility and negotiability, with the 2028, 2031 and 2035 activity dates

One TLS configuration cannot satisfy all four. Build the capability to differ by endpoint, and design to the strictest regime your traffic touches.

For UK organisations with global operations this is now a design constraint, not a compliance footnote. It is also the strongest practical argument for crypto-agility that your board will understand: the requirement itself changes by jurisdiction and by year.

Governance, money, and the six questions for suppliers

Make it a programme, not a project

Name an accountable owner with a board mandate. Close to half of enterprises have nobody. Programmes without an owner stop after discovery.

Budget as multi-year capital. NCSC is blunt that the total cost could be significant, including preparation. Align spend to refresh cycles you were funding anyway.

Put it in the risk register with a named tolerance. UK financial services already have to evidence emerging risk under the operational resilience framework, and regulators will treat published national guidance as the benchmark for reasonable measures.

Publish a statement of intent. NCSC suggests this so suppliers can see the demand. It costs a page and it moves your vendors.

Six questions for every supplier

- 1 Where do your products use RSA or ECC today?
- 2 What is your dated PQC roadmap, by product and version?
- 3 Which final FIPS algorithms and parameter sets, hybrid or pure?
- 4 Software update, firmware update, or hardware replacement?
- 5 Can you provide a cryptographic bill of materials?
- 6 What will you commit to contractually for 2031 and 2035?

If you need assured help, the NCSC PQC pilot has published its list of consultancies assessed against its standard for discovery and migration planning, and separately for advice. Expressions of interest are closed. Public sector buyers route through the Government Commercial Agency dynamic purchasing system.

Put the six questions into your next procurement template and your existing contract review cycle. That is the cheapest control on this slide.

If you are not running a migration programme



Four recommendations for SMEs

1

Keep everything current

Most migration arrives as an automatic update you do not have to plan (e.g., Chrome, Edge, Firefox, Signal, iMessage default to PQC).

2

Refresh EOL hardware on normal cycles

Routers, laptops, and phones past support are your real exposure. Replacing them on schedule is your migration.

3

Ask providers for confirmation

If an MSP or SaaS provider runs your services, ask them to confirm they are doing cryptographic discovery. Get it in writing.

4

Follow the same dates for custom software

NCSC is explicit that bespoke or specialist software must follow the large organisation timetable, regardless of your business size.



And what not to do

1

Do not buy unvalidated solutions: Avoid anything marketed as "quantum proof" that lacks a finalised FIPS standard and a validation certificate.

2

Do not implement custom crypto: NCSC explicitly advises against creating your own cryptography. This applies to your suppliers as well.

3

Do not confuse QKD with PQC: Quantum key distribution and post-quantum cryptography are different; only PQC is in the NCSC timeline.

4

Do not rely on green ticks: Hybrid TLS with a green tick is not a completed migration. Your underlying certificates are still classical.

For most small organisations on commodity IT, this transition should be largely invisible. That is the design. The exception is anywhere you run something bespoke, specialist or old.

Three by Friday, three by Christmas

By Friday

- 1 Name the accountable owner for PQC migration, in writing
- 2 List your five most exposed internet-facing TLS endpoints
- 3 Send the six questions to one strategic supplier

By Christmas

- 1 A first-pass CBOM covering everything internet-facing
- 2 Hybrid key exchange live on those five endpoints, with monitoring
- 3 A one page statement of intent, signed off and published

Say one commitment out loud, or put it in the chat. Then answer the opening poll again.

If your answer to the poll was A or B, everything on the left hand side of this slide moves you to C by the end of next week, and none of it needs a business case.
The 2028 NCSC checkpoint is a discovery and planning checkpoint. You can pass it starting from here.

Just landed, and what lands next

26 OCT

UK Cyber Security & Resilience Bill

Lords report stage. Committee finished 7 Sept. Royal Assent expected late 2026 or early 2027; CAF goes statutory.

21 SEP

FIPS 140-2 sunset, now in effect

Remaining certificates are now Historical. New US federal procurement needs FIPS 140-3 validated modules.

11 SEP

EU CRA reporting duties, now live

Article 14 obligations now apply to products with a digital element sold into the EU.

22 OCT

US PQC migration plans due

120 days after M-26-15 (24 June). Expect a wave of vendor announcements timed to it. Use them to press your own suppliers.

22 SEP

Gartner SRM Summit, London

Under half of CISOs have started PQC and only 8% can see their inventory. Benchmark yourself against it.

13 OCT

OpenSSL Conference, Prague

Runs 13 to 15 Oct. The library layer decides what your estate can negotiate. Track the provider and hybrid group roadmap.

Live, but no date yet

- HQC draft standard still pending, final expected 2027
- FIPS 206 (FN-DSA), final expected late 2026 or early 2027
- IETF work on ML-DSA in TLS, the gate on post-quantum authentication
- CA/Browser Forum ballots on post-quantum signatures in certificates
- NCSC Annual Review 2026, with refreshed incident figures
- Minimum CBOM elements from CISA and NIST, due around March 2027

The CBOM date matters most. Build a working inventory now, but do not over-engineer the format before the taxonomy exists.

Two of these change what suppliers can sell you. Take them into your next procurement conversation.

Take these away

- 1 No CRQC exists, and the preparation window is still the binding constraint
- 2 Separate key establishment from authentication. Only one is solvable this quarter
- 3 Deploy only finalised standards. Design so you can change them
- 4 2028 is a discovery and planning checkpoint. It is passable from a standing start

Questions

Bring me the one system you already know is going to be a problem. That conversation is worth more than the rest of this deck.

Primary sources

- NCSC, Timelines for migration to post-quantum cryptography
- NCSC, Next steps in preparing for post-quantum cryptography
- NCSC, Assured Cyber Security Consultancy, PQC pilot
- NIST FIPS 203, 204 and 205, plus SP 800-208
- NIST IR 8610, additional signatures round 3, May 2026
- RFC 9794, post-quantum terminology
- US Executive Order 14412 and OMB M-26-15, June 2026
- DigiCert Quantum Readiness Outlook, July 2026
- Measurement study of post-quantum readiness of the internet, 2026
- Gartner SRM Summit London, via Computing, 22 September 2026

What NCSC expects organisations to have built and rehearsed



Know your critical systems

Map essential services to the IT and OT that deliver them, with a definitive OT asset inventory and MSP dependencies.



Plan for degraded operations

Realistic playbooks for running with IT or OT partially unavailable, with pre-agreed decision rights.



Rehearse the hard actions

Segmentation, isolation and clean rebuild practised in advance, ideally through NCSC CIE-assured exercising.



Enhanced threat hunting

Proactive hunting and Early Warning Service enrolment so escalation is detected before disruption.



Leadership decision frameworks

Boards understand the operational cost of security actions and can authorise them quickly.



Revisit CAF through a severe-threat lens

CAF compliance in normal conditions is the floor; CSR Bill puts CAF on a statutory footing.



OPEN FLOOR & DISCUSSION

Questions & Answers

Thank you for your time. Let's open the floor to discuss technical implementation, architecture, and immediate next steps.

TOPIC 01

PQC Migration Strategy & CBOM Inventory

TOPIC 02

Standards, Compliance & NCSC 2028 Checkpoints

TOPIC 03

Supplier Engagement & TLS Endpoint Readiness



Andrew Gravett

Lead Security Architect

October 2026